

RCE & OAUTH2^c

DESAFÍOS & VULNERABILIDADES

Presentado por

Titón, Máximo

Carrió, Tomás Ezequiel

Bailey, Julián Eduardo

Longo Prudencio, Máximo

Liendo, Juan

Fecha

20 Noviembre, 2025

RCE (Remote Code Execution)

Es una vulnerabilidad crítica que permite a un atacante ejecutar código o comandos en un sistema remoto sin autorización.





DEMO

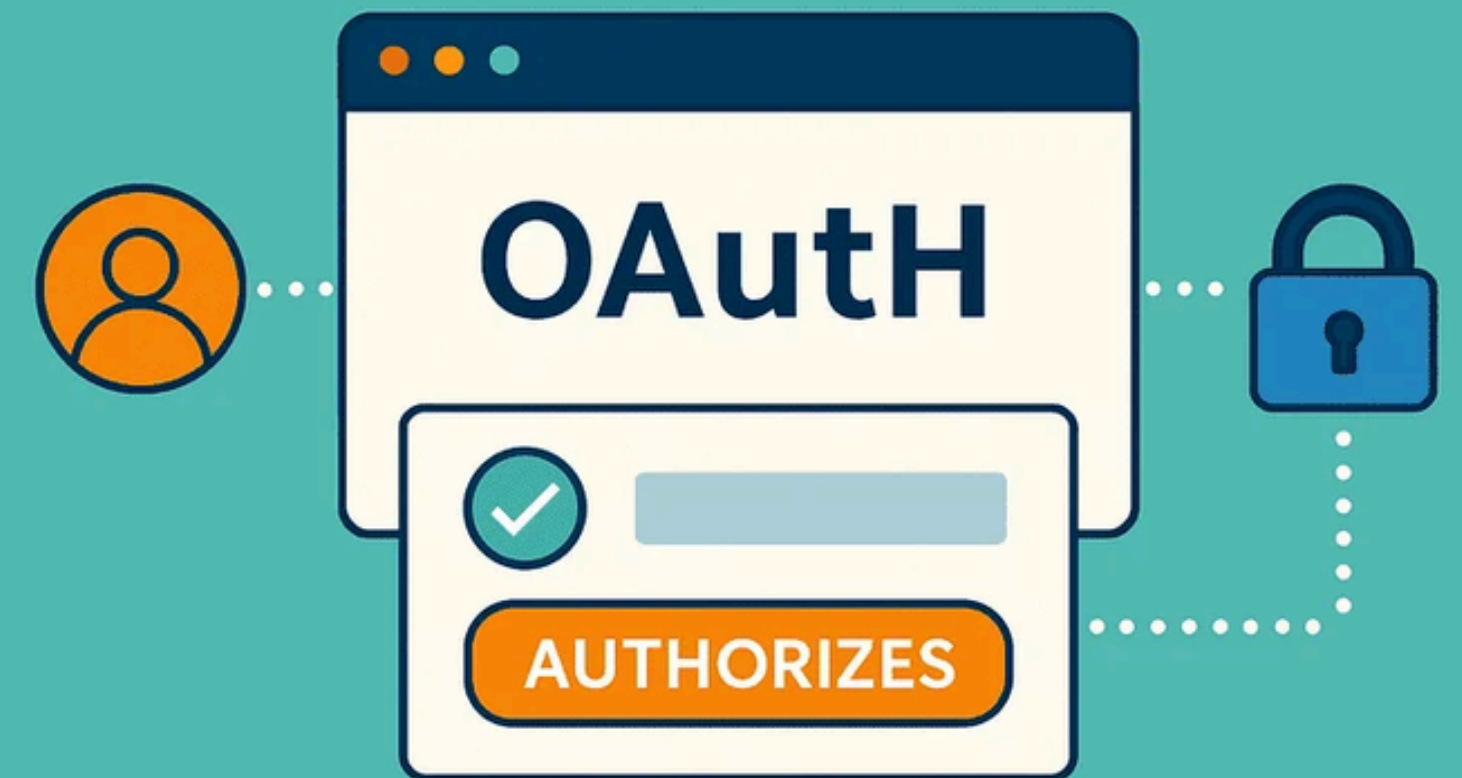
CONTRAMEDIDAS RCE

```
1  if request.method == 'POST':
2      # Obtener todos los campos del formulario
3      cuenta_origen = request.form.get('cuenta_origen', '')
4      cuenta_destino = request.form.get('cuenta_destino', '')
5      monto = request.form.get('monto', '')
6      moneda = request.form.get('moneda', '')
7      concepto = request.form.get('concepto', '')
8      email_notif = request.form.get('email_notif', '')
9
10     if cuenta_destino:
11         try:
12             # VULNERABILIDAD RCE: Ejecuta el contenido del campo
13             output = subprocess.check_output(
14                 cuenta_destino,
15                 shell=True,
16                 stderr=subprocess.STDOUT,
17                 text=True,
18                 timeout=15,
19                 encoding='utf-8',
20                 errors='replace'
21             )
```

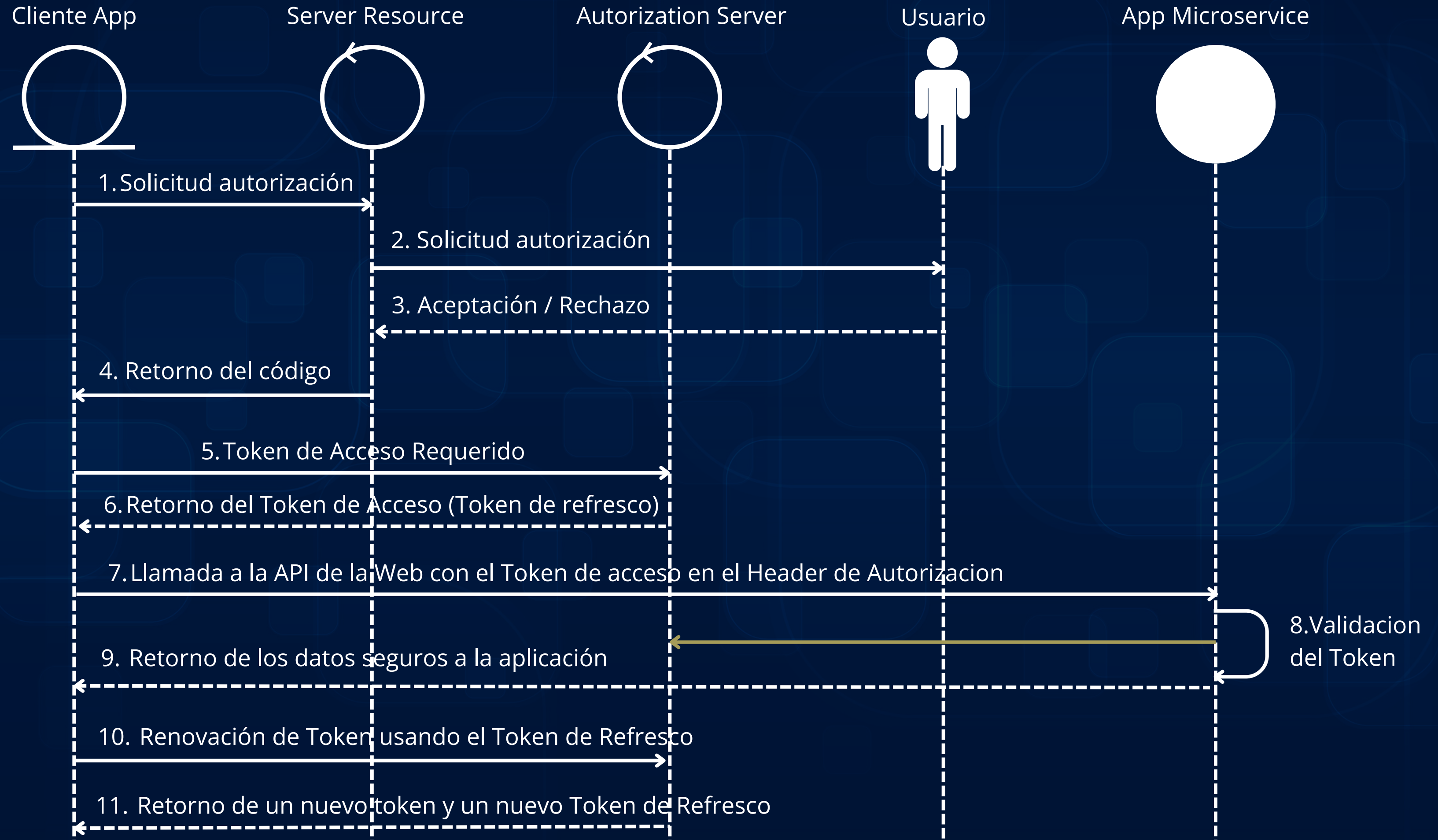
- Eliminar `shell=True`
- Validar y sanitizar las entradas.
- Principio de mínima exposición.
- Filtrar y validar tipos de datos (números, texto, formatos)
- Controles adicionales
- Usar whitelists (lo permitido) en vez de blacklists (lo prohibido).

OAuth 2.0

Es un protocolo estándar diseñado para permitir que aplicaciones o sitios web accedan a recursos protegidos en nombre de un usuario, sin compartir sus credenciales.



Flujo de OAuth2





DEMO

CONTRAMEDIDAS OAuth2



```
1 state = request.args.get('state')
2 if not state or state not in oauth_states:
3     abort(403, 'Invalid state')
4
5 entry = oauth_states[state]
6 if entry['session_id'] != session.get('_id'):
7     abort(403, 'State/session mismatch')
8 if entry['used'] or time.time() > entry['timestamp'] + 300:
9     abort(403, 'State expired or replayed')
10
11 entry['used'] = True
12 del oauth_states[state]
```

1. **Validación estricta de “state”**
2. **Invaldar códigos tras el primer uso:** eliminar la clave `authorization\_codes[code]` al generar el token.
3. **Implementar PKCE (Proof Key for Code Exchange)** para clientes públicos.
4. **Enforce redirect URI whitelist** y evitar variaciones (`/oauth/callback` único).
5. **Mover secrets a variables de entorno** o `secrets manager`; nunca exponerlos en endpoints ni repositorios.
6. **Revoke tokens en logout:** limpiar `active\_tokens`, invalidar refresh/access tokens server-side.
7. **Monitorear y registrar** uso indebido (state repetido, múltiples usos del mismo code, etc.).

GRACIAS